Vendor Compliance & Procurement Policy

This document defines the internal policies used by the company to evaluate and approve third party vendors. The purpose of these policies is to ensure that all vendors meet security, legal, and operational standards before entering into business relationships with the organization.

All incoming vendor agreements, purchase orders, and contracts are automatically reviewed by the Vendor Compliance Agent. The system extracts relevant data from submitted documents and validates the information against the policies defined in this document.

Key Policy Areas:

- Vendor security certifications
- Financial approval thresholds
- Contract signature requirements
- Data protection standards
- Vendor approval workflow
- Jurisdictional restrictions

Section 1 — Vendor Security Requirements

- All vendors handling company or customer data must possess a valid ISO 27001 certification.
- Vendors without ISO 27001 must provide equivalent security documentation and will require manual security review.
- Vendors processing personal data must demonstrate GDPR compliance.
- Vendors must provide documentation describing their incident response process.

Section 2 — Financial Approval Rules

- Contracts with a total value below $10,000 can be approved automatically.
- Contracts between $10,000 and $50,000 require secondary approval from the Finance Department.
- Contracts exceeding $50,000 require executive approval.
- Payment terms longer than 90 days require finance review.

Section 3 — Contract Validation and Vendor Approval

- All contracts must contain the vendor legal name and registration number.
- Contracts must be signed by an authorized representative of the vendor.
- High risk vendors must be reviewed by the compliance team.
- Any missing mandatory fields will automatically trigger a human review workflow.

Section 4 - Jurisdictional Restrictions

Approved Jurisdictions: EU, USA, UK, Canada, and Georgia.

Restricted Jurisdictions: Any country currently under international trade sanctions. Contracts from these regions **MUST** be flagged as "Non-Compliant" regardless of contract value.

High-Risk Regions: Singapore, UAE, and Brazil. These require secondary compliance review.